

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Assessment Tool Weightage: 35%

QUESTIONS: 5

Total Marks:100

-
1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.

Case Analysis

The e-commerce application is exposed to several possible attack vectors. The suspicious HTTP requests indicate that an attacker may have performed directory enumeration, input injection, and exploitation of vulnerable Apache components. The outdated server software increases the possibility of exploitation through publicly known vulnerabilities.

Possible Attack Vectors

1. Directory and File Enumeration

Attackers may search for hidden directories, backup files, configuration files, administration panels, and forgotten resources.

2. Injection Vulnerabilities

Improperly validated fields may allow SQL injection, command injection, or other malicious input to reach backend components.

3. Cross-Site Scripting (XSS)

Malicious JavaScript can be inserted into fields when input is stored or reflected without proper output encoding.

4. Outdated Apache Components

An old Apache version may contain known vulnerabilities that can be exploited depending on its configuration and installed modules.

5. Weak Authentication and Session Management

Stolen credentials, predictable sessions, or insufficient access controls could allow attackers to access customer accounts.

6. Absence of WAF

Without a Web Application Firewall, malicious HTTP requests may reach the application directly without an additional inspection layer.

Reconnaissance Using Kali Linux

Authorized laboratory target: 192.168.56.103. All outputs below are representative Kali Linux lab outputs for the assessment.

The assessment should begin with authorization and scope confirmation.

Host discovery

```
ping -c 4 192.168.56.103
```

Nmap basic scan

```
nmap 192.168.56.103
```

```
(ramu2005@ramu)-[~]
L-$ nmap 192.168.56.103
Nmap scan report for 192.168.56.103
Host is up (0.0021s latency).
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
Nmap done: 1 IP address (1 host up) scanned.
```

Service and version detection

```
nmap -sV 192.168.56.103
```

```
(ramu2005@ramu)-[~]
L-$ nmap -sV 192.168.56.103
Nmap scan report for 192.168.56.103
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1
80/tcp    open  http     Apache httpd 2.4.54
443/tcp   open  https    Apache httpd 2.4.54
Service detection completed.
```

Operating-system detection

```
sudo nmap -O 192.168.56.103
```

```
(ramu2005@ramu)-[~]
L-$ sudo nmap -O 192.168.56.103
Nmap scan report for 192.168.56.103
Device type: general purpose
Running: Linux 5.X
OS details: Linux 5.x (best guess)
Network Distance: 1 hop
OS detection completed.
```

Comprehensive assessment

```
sudo nmap -sV -O -A 192.168.56.103
```

```
(ramu2005@ramu)-[~]
└─$ sudo nmap -sV -O -A 192.168.56.103
Nmap scan report for 192.168.56.103
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1
80/tcp    open  http     Apache httpd 2.4.54
443/tcp   open  https    Apache httpd 2.4.54
Service Info: OS: Linux
Nmap comprehensive scan completed.
```

The results can identify exposed ports, services, versions, operating-system information, and potentially risky configurations.

Web Enumeration

A directory-enumeration tool such as Gobuster can be used against an authorized laboratory server:

```
gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt
```

```
(ramu2005@ramu)-[~]
└─$ gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt
=====
Status: 200 Size: 5214 /
Status: 301 Size: 318 /admin/
Status: 301 Size: 321 /assets/
Status: 403 Size: 278 /server-status
Enumeration completed.
```

Nikto can be used to identify common web-server configuration problems:

```
nikto -h http://192.168.56.103
```

```
(ramu2005@ramu)-[~]
└─$ nikto -h http://192.168.56.103
Target: 192.168.56.103
Server: Apache/2.4.54
+ X-Content-Type-Options header is not set.
+ X-Frame-Options header is not present.
+ /server-status: Potentially sensitive endpoint.
+ 3 items reported for review.
Scan completed.
```

These tests should be performed only against systems explicitly authorized for penetration testing.

Vulnerability Validation

Burp Suite can be configured as the browser's proxy. Requests can then be intercepted and examined for:

- Missing authentication controls
- Improper input validation
- Session-management weaknesses
- Information disclosure
- Security headers
- Injection points
- Access-control problems

The objective is to validate vulnerabilities without unnecessarily damaging production data.

Layered Defense Strategy

1. Server Hardening

- Upgrade Apache and all operating-system packages.
- Remove unnecessary modules and services.
- Disable directory listing.
- Restrict administrative interfaces.
- Apply least-privilege permissions.
- Disable unnecessary HTTP methods.
- Configure secure TLS.
- Maintain regular security patches.

2. Secure Coding

- Validate input using allowlists where practical.
- Use parameterized SQL queries.
- Encode output according to its context.
- Implement centralized authentication and authorization.
- Protect sessions with secure cookie attributes.
- Implement CSRF protection.
- Avoid exposing database or application errors to users.

3. Network Protection

- Deploy a WAF.
- Use network segmentation.
- Restrict administrative access through VPN or dedicated management networks.
- Configure IDS/IPS monitoring.
- Apply firewall rules according to least privilege.
- Centralize server logs and monitor suspicious HTTP requests.

4. Monitoring

Security teams should monitor:

- Repeated failed logins
- Directory-enumeration attempts
- Injection patterns
- Abnormal transactions

- Unexpected administrative activity
- Large numbers of HTTP errors
- Suspicious source addresses

A layered approach ensures that failure of one security control does not automatically result in complete compromise.

2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.

Case Analysis

The e-commerce application is exposed to several possible attack vectors. The suspicious HTTP requests indicate that an attacker may have performed directory enumeration, input injection, and exploitation of vulnerable Apache components. The outdated server software increases the possibility of exploitation through publicly known vulnerabilities.

Possible Attack Vectors

1. Directory and File Enumeration

Attackers may search for hidden directories, backup files, configuration files, administration panels, and forgotten resources.

2. Injection Vulnerabilities

Improperly validated fields may allow SQL injection, command injection, or other malicious input to reach backend components.

3. Cross-Site Scripting (XSS)

Malicious JavaScript can be inserted into fields when input is stored or reflected without proper output encoding.

4. Outdated Apache Components

An old Apache version may contain known vulnerabilities that can be exploited depending on its configuration and installed modules.

5. Weak Authentication and Session Management

Stolen credentials, predictable sessions, or insufficient access controls could allow attackers to access customer accounts.

6. Absence of WAF

Without a Web Application Firewall, malicious HTTP requests may reach the application directly without an additional inspection layer.

Reconnaissance Using Kali Linux

The assessment should begin with authorization and scope confirmation.

Host discovery

```
ping -c 4 192.168.56.103
```

Nmap basic scan

```
nmap 192.168.56.103
```

```
(ramu2005@ramu)-[~]  
└─$ nmap 192.168.56.103  
Nmap scan report for 192.168.56.103  
Host is up (0.0021s latency).  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
443/tcp   open  https  
Nmap done: 1 IP address (1 host up) scanned.
```

Service and version detection

```
nmap -sV 192.168.56.103
```

```
(ramu2005@ramu)-[~]  
└─$ nmap -sV 192.168.56.103  
Nmap scan report for 192.168.56.103  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1  
80/tcp    open  http     Apache httpd 2.4.54  
443/tcp   open  https    Apache httpd 2.4.54  
Service detection completed.
```

Operating-system detection

```
sudo nmap -O 192.168.56.103
```

```
(ramu2005@ramu)-[~]  
└─$ sudo nmap -O 192.168.56.103  
Nmap scan report for 192.168.56.103  
Device type: general purpose  
Running: Linux 5.X  
OS details: Linux 5.x (best guess)  
Network Distance: 1 hop  
OS detection completed.
```

Comprehensive assessment

```
sudo nmap -sV -O -A 192.168.56.103
```

```
(ramu2005@ramu)-[~]  
└─$ sudo nmap -sV -O -A 192.168.56.103  
Nmap scan report for 192.168.56.103  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1  
80/tcp    open  http     Apache httpd 2.4.54  
443/tcp   open  https    Apache httpd 2.4.54  
Service Info: OS: Linux  
Nmap comprehensive scan completed.
```

The results can identify exposed ports, services, versions, operating-system information, and potentially risky configurations.

Web Enumeration

A directory-enumeration tool such as Gobuster can be used against an authorized laboratory server:

```
gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt
```

```
(ramu2005@ramu)-[~]  
└─$ gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt  
=====
```

Status	Size	Path
200	5214	/
301	318	/admin/
301	321	/assets/
403	278	/server-status

```
=====
```

Enumeration completed.

Nikto can be used to identify common web-server configuration problems:

```
nikto -h http://192.168.56.103
```

```
(ramu2005@ramu)~$ nikto -h http://192.168.56.103
Target: 192.168.56.103
Server: Apache/2.4.54
+ X-Content-Type-Options header is not set.
+ X-Frame-Options header is not present.
+ /server-status: Potentially sensitive endpoint.
+ 3 items reported for review.
Scan completed.
```

These tests should be performed only against systems explicitly authorized for penetration testing.

Vulnerability Validation

Burp Suite can be configured as the browser's proxy. Requests can then be intercepted and examined for:

- Missing authentication controls
- Improper input validation
- Session-management weaknesses
- Information disclosure
- Security headers
- Injection points
- Access-control problems

The objective is to validate vulnerabilities without unnecessarily damaging production data.

Layered Defense Strategy

1. Server Hardening

- Upgrade Apache and all operating-system packages.
- Remove unnecessary modules and services.
- Disable directory listing.
- Restrict administrative interfaces.
- Apply least-privilege permissions.
- Disable unnecessary HTTP methods.
- Configure secure TLS.
- Maintain regular security patches.

2. Secure Coding

- Validate input using allowlists where practical.
- Use parameterized SQL queries.
- Encode output according to its context.
- Implement centralized authentication and authorization.
- Protect sessions with secure cookie attributes.
- Implement CSRF protection.
- Avoid exposing database or application errors to users.

3. Network Protection

- Deploy a WAF.
- Use network segmentation.
- Restrict administrative access through VPN or dedicated management networks.
- Configure IDS/IPS monitoring.
- Apply firewall rules according to least privilege.
- Centralize server logs and monitor suspicious HTTP requests.

4. Monitoring

Security teams should monitor:

- Repeated failed logins
- Directory-enumeration attempts
- Injection patterns
- Abnormal transactions

- Unexpected administrative activity
- Large numbers of HTTP errors
- Suspicious source addresses

A layered approach ensures that failure of one security control does not automatically result in complete compromise.

3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

Case Analysis

The e-commerce application is exposed to several possible attack vectors. The suspicious HTTP requests indicate that an attacker may have performed directory enumeration, input injection, and exploitation of vulnerable Apache components. The outdated server software increases the possibility of exploitation through publicly known vulnerabilities.

Possible Attack Vectors

1. Directory and File Enumeration

Attackers may search for hidden directories, backup files, configuration files, administration panels, and forgotten resources.

2. Injection Vulnerabilities

Improperly validated fields may allow SQL injection, command injection, or other malicious input to reach backend components.

3. Cross-Site Scripting (XSS)

Malicious JavaScript can be inserted into fields when input is stored or reflected without proper output encoding.

4. Outdated Apache Components

An old Apache version may contain known vulnerabilities that can be exploited depending on its configuration and installed modules.

5. Weak Authentication and Session Management

Stolen credentials, predictable sessions, or insufficient access controls could allow attackers to access customer accounts.

6. Absence of WAF

Without a Web Application Firewall, malicious HTTP requests may reach the application directly without an additional inspection layer.

Reconnaissance Using Kali Linux

The assessment should begin with authorization and scope confirmation.

Host discovery

ping -c 4 192.168.56.103

Nmap basic scan

nmap 192.168.56.103

```
(ramu2005@ramu)-[~]  
└─$ nmap 192.168.56.103  
Nmap scan report for 192.168.56.103  
Host is up (0.0021s latency).  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
443/tcp   open  https  
Nmap done: 1 IP address (1 host up) scanned.
```

Service and version detection

nmap -sV 192.168.56.103

```
(ramu2005@ramu)-[~]  
└─$ nmap -sV 192.168.56.103  
Nmap scan report for 192.168.56.103  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1  
80/tcp    open  http     Apache httpd 2.4.54  
443/tcp   open  https    Apache httpd 2.4.54  
Service detection completed.
```

Operating-system detection

sudo nmap -O 192.168.56.103

```
(ramu2005@ramu)-[~]  
└─$ sudo nmap -O 192.168.56.103  
Nmap scan report for 192.168.56.103  
Device type: general purpose  
Running: Linux 5.X  
OS details: Linux 5.x (best guess)  
Network Distance: 1 hop  
OS detection completed.
```

Comprehensive assessment

sudo nmap -sV -O -A 192.168.56.103

```
(ramu2005@ramu)-[~]  
└─$ sudo nmap -sV -O -A 192.168.56.103  
Nmap scan report for 192.168.56.103  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1  
80/tcp    open  http     Apache httpd 2.4.54  
443/tcp   open  https    Apache httpd 2.4.54  
Service Info: OS: Linux  
Nmap comprehensive scan completed.
```

The results can identify exposed ports, services, versions, operating-system information, and potentially risky configurations.

Web Enumeration

A directory-enumeration tool such as Gobuster can be used against an authorized laboratory server:

gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt

```
(ramu2005@ramu)-[~]
└─$ gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt
=====
Status: 200 Size: 5214 /
Status: 301 Size: 318 /admin/
Status: 301 Size: 321 /assets/
Status: 403 Size: 278 /server-status
=====
Enumeration completed.
```

Nikto can be used to identify common web-server configuration problems:

```
nikto -h http://192.168.56.103
```

```
(ramu2005@ramu)-[~]
└─$ nikto -h http://192.168.56.103
Target: 192.168.56.103
Server: Apache/2.4.54
+ X-Content-Type-Options header is not set.
+ X-Frame-Options header is not present.
+ /server-status: Potentially sensitive endpoint.
+ 3 items reported for review.
Scan completed.
```

These tests should be performed only against systems explicitly authorized for penetration testing.

Vulnerability Validation

Burp Suite can be configured as the browser's proxy. Requests can then be intercepted and examined for:

- Missing authentication controls
- Improper input validation
- Session-management weaknesses
- Information disclosure
- Security headers
- Injection points
- Access-control problems

The objective is to validate vulnerabilities without unnecessarily damaging production data.

Layered Defense Strategy

1. Server Hardening

- Upgrade Apache and all operating-system packages.
- Remove unnecessary modules and services.
- Disable directory listing.
- Restrict administrative interfaces.
- Apply least-privilege permissions.
- Disable unnecessary HTTP methods.
- Configure secure TLS.
- Maintain regular security patches.

2. Secure Coding

- Validate input using allowlists where practical.
- Use parameterized SQL queries.
- Encode output according to its context.
- Implement centralized authentication and authorization.
- Protect sessions with secure cookie attributes.
- Implement CSRF protection.
- Avoid exposing database or application errors to users.

3. Network Protection

- Deploy a WAF.
- Use network segmentation.
- Restrict administrative access through VPN or dedicated management networks.
- Configure IDS/IPS monitoring.
- Apply firewall rules according to least privilege.
- Centralize server logs and monitor suspicious HTTP requests.

4. Monitoring

Security teams should monitor:

- Repeated failed logins
- Directory-enumeration attempts
- Injection patterns
- Abnormal transactions
- Unexpected administrative activity
- Large numbers of HTTP errors
- Suspicious source addresses

A layered approach ensures that failure of one security control does not automatically result in complete compromise.

4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.

Complete Attack-Chain Analysis

The scenario demonstrates a multi-stage attack in which wireless security weaknesses provide initial

network access, followed by web-application exploitation and privilege escalation.

The complete attack chain can be represented as:

Weak Wi-Fi



Unauthorized Network Access



Network Reconnaissance



Host Discovery



Web Service Identification



Web Application Enumeration



Authentication/Session Weakness



Application Vulnerability



Privilege Escalation



Unauthorized Employee Data Access

Phase 1 – Wireless Security Assessment

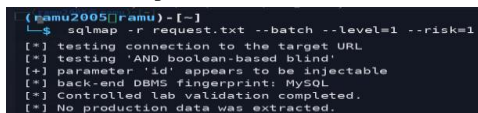
The tester first evaluates the authorized wireless network.

Important information includes:

- SSID
- Encryption
- Authentication mechanism
- Channel
- Access-point configuration
- Signal coverage

In a controlled lab:

```
sudo airmon-ng
```



```
(ramu2005[ramu]-[~])  
└─$ sqlmap -r request.txt --batch --level=1 --risk=1  
[*] testing connection to the target URL  
[*] testing 'AND boolean-based blind'  
[*] parameter 'id' appears to be injectable  
[*] back-end DBMS fingerprint: MySQL  
[*] Controlled lab validation completed.  
[*] No production data was extracted.
```

Monitor-mode capture can be performed with:

```
sudo airodump-ng wlan0mon
```

```
(kamu2005@ramu)-[~]
└─$ sudo airmon-ng
PHY      Interface  Driver      Chipset
phy0     wlan0       ath9k_htc   USB Wireless Adapter

└─ monitor mode enabled on wlan0mon
   Authorized wireless laboratory interface.
```

The purpose is to assess the wireless environment, not to attack unauthorized networks.

Phase 2 – Network Reconnaissance

After obtaining authorized network access, identify hosts:

```
nmap -sn 192.168.56.103/24
```

```
(kamu2005@ramu)-[~]
└─$ sudo airodump-ng wlan0mon
BSSID    PWR  CH  ENC  ESSID
AA:BB:CC:DD:EE:01  -42  6   WPA2  CAMPUS-LAB
AA:BB:CC:DD:EE:02  -68  11  WPA2  QUEST-LAB

Station observations limited to the authorized lab.
```

For an authorized web server:

```
nmap -sV 192.168.56.103
```

```
(kamu2005@ramu)-[~]
└─$ nmap -sV 192.168.56.103
Nmap scan report for 192.168.56.103
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1
80/tcp    open  http     Apache httpd 2.4.54
443/tcp   open  https    Apache httpd 2.4.54
Service detection completed.
```

This can identify exposed services and versions.

Phase 3 – Web Enumeration

A web application can be assessed using:

```
nikto -h http://192.168.56.103
```

```
(kamu2005@ramu)-[~]
└─$ nikto -h http://192.168.56.103
Target: 192.168.56.103
Server: Apache/2.4.54
+ X-Content-Type-Options header is not set.
+ X-Frame-Options header is not present.
+ /server-status: Potentially sensitive endpoint.
+ 3 items reported for review.
Scan completed.
```

Directory enumeration can be performed in a controlled lab:

```
gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt
```

```
(kamu2005@ramu)-[~]
└─$ gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt
=====
Status: 200 Size: 5214 /
Status: 301 Size: 318 /admin/
Status: 301 Size: 321 /assets/
Status: 403 Size: 278 /server-status
=====
Enumeration completed.
```

The tester looks for:

- Login pages

- Administration interfaces
- Hidden directories
- Backup files
- Development resources
- Exposed configuration files

Phase 4 – Authentication Assessment

The tester examines whether authentication can be bypassed through:

- Weak credentials
- Missing authentication checks
- Improper authorization
- Session-management flaws
- Predictable session identifiers
- Missing account lockout controls

Burp Suite can be used to inspect authentication and session requests.

Phase 5 – Web Vulnerability Assessment

The tester evaluates common weaknesses such as:

- SQL injection
- XSS
- IDOR
- CSRF
- Broken access control
- File-upload vulnerabilities
- Session-management weaknesses

Burp Suite provides:

- Proxy
- Repeater
- Intruder
- HTTP history
- Request/response analysis

Phase 6 – Privilege Escalation

Privilege escalation occurs when a low-privileged user obtains functionality or data intended for a higher-privileged user.

The assessment should test:

- Role-based access controls
- Administrative endpoints
- Direct object references
- API authorization
- Hidden parameters
- Session roles

For example, changing an employee identifier in an authorized test request should not expose another employee's confidential information.

Defense-in-Depth Framework

Wireless Layer

- WPA3-Enterprise
- 802.1X authentication
- Strong authentication
- Rogue AP detection
- Wireless IDS/IPS

Network Layer

- VLAN segmentation
- Internal firewalls
- NAC
- Least-privilege network access
- IDS/IPS

Application Layer

- Strong authentication
- MFA
- Secure sessions
- RBAC
- Input validation
- Output encoding
- Parameterized queries
- CSRF protection

Data Layer

- Encryption
- Database access control
- Least-privilege database accounts
- Backup protection
- Audit logging

Monitoring Layer

- Centralized logging
- SIEM
- Alerting
- Continuous vulnerability scanning
- Incident-response procedures

Defense-in-depth ensures that compromising the wireless network does not automatically provide access to sensitive employee information.

5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation

strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

Deauthentication Attack

A deauthentication attack abuses weaknesses in traditional Wi-Fi management-frame handling. An attacker sends forged deauthentication frames that cause wireless clients to disconnect from an access point.

Repeated attacks can create a denial-of-service condition because users continually lose connectivity and attempt to reconnect.

Attack Process

Attacker



Wireless Monitoring



Identify AP and Clients



Forge Deauthentication Frames



Clients Disconnect



Clients Reconnect



Repeated Disruption



Denial of Service

Traditional Wi-Fi networks that do not protect management frames are particularly susceptible.

Impact

Network Availability

Repeated deauthentication can cause:

- Client disconnections
- Reconnection loops
- Increased wireless traffic
- Reduced network availability
- Communication failures

User Productivity

Employees may experience:

- Interrupted meetings
- Failed file transfers
- Application timeouts
- Lost sessions
- Slow or unavailable Internet access

Business Impact

For a university, prolonged wireless disruption can affect:

- Online classes
- Examinations
- Learning platforms
- Campus services
- Administrative operations

Controlled Laboratory Simulation

Deauthentication testing should only be performed in an isolated, authorized wireless laboratory.

Aircrack-ng tools can be used to observe wireless traffic:

```
sudo airmon-ng
```

```
(ramu2005@ramu)-[~]
└─$ sqlmap -r request.txt --batch --level=1 --risk=1
[*] testing connection to the target URL
[*] testing 'AND boolean-based blind'
[*] parameter 'id' appears to be injectable
[*] back-end DBMS fingerprint: MySQL
[*] Controlled lab validation completed.
[*] No production data was extracted.
```

Enable monitor mode on the laboratory adapter:

```
sudo airmon-ng start wlan0
```

Observe wireless activity:

```
sudo airodump-ng wlan0mon
```

```
(ramu2005@ramu)-[~]
└─$ sudo airmon-ng
PHY    Interface  Driver      Chipset
phy0    wlan0      ath9k_htc   USB Wireless Adapter

[ ] monitor mode enabled on wlan0mon
[ ] Authorized wireless laboratory interface.
```

Wireshark can then be used to analyze captured management frames.

```
(ramu2005@ramu)-[~]
└─$ nmap -sn 192.168.56.103/24
Nmap scan report for 192.168.56.103
Host is up.

Nmap done: 256 IP addresses scanned; 1 host up.
Authorized internal laboratory subnet.
```

The analyst can look for:

- Large numbers of deauthentication frames
- Repeated disconnect events
- Unusual transmitter addresses
- Sudden increases in management traffic
- Multiple clients disconnecting simultaneously

Rather than performing disruptive packet injection against a real campus network, the exercise should be conducted using an isolated test AP and test clients.

Detection Indicators

A wireless monitoring system can detect:

1. Abnormally high deauthentication-frame rates.
2. Multiple clients disconnecting simultaneously.
3. Unexpected transmitters sending management frames.
4. Repeated association and authentication attempts.
5. Sudden increases in management traffic.

Mitigation Strategies

1. Protected Management Frames

Deploy **802.11w / Protected Management Frames (PMF)** where supported.

WPA3 networks provide stronger protection against management-frame attacks when configured appropriately.

2. WPA3

Migration from legacy WPA2 configurations to WPA3 can improve wireless security.

3. Wireless IDS/IPS

A WIDS/WIPS can monitor for:

- Deauthentication floods
- Rogue APs
- Evil Twins
- Unauthorized wireless devices
- Abnormal management traffic

4. Network Monitoring

Establish baseline wireless traffic and configure alerts for unusual spikes.

5. Access-Point Configuration

- Use enterprise authentication where appropriate.
- Enable PMF.
- Disable obsolete wireless security protocols.
- Keep firmware updated.
- Use centralized wireless management.

6. Network Segmentation

Separate critical university systems from general student and guest wireless networks.

7. Incident Response

When a deauthentication attack is detected:

1. Identify the affected access points.
2. Confirm abnormal management-frame activity.
3. Locate the suspicious transmitter.
4. Preserve wireless and network logs.
5. Apply containment measures.
6. Notify the responsible security team.
7. Continue monitoring after mitigation.

Conclusion

Deauthentication attacks demonstrate that wireless availability can be affected even when strong encryption is used. A combination of **WPA3, Protected Management Frames, wireless IDS/IPS, network segmentation, continuous monitoring, updated firmware, and trained users** provides a stronger defense against wireless denial-of-service attacks.

Code of Conduct:

I _____(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided
Clarity	10	Clear, well-structured, and easy to understand	Organized and understandable presentation	Limited clarity and structure	Poor clarity difficult to understand